

V18 Post-Auditor Audit Report

BahiKhata Pro — Comprehensive Audit After Auditor Fixes

Report Date	2026-07-12
Audit Scope	Full codebase audit after auditor commit 8d61e2f
Auditor Commit	V18: as-of TZ fix, dead-field cleanup, green test suite, branded Paise type
Tests	739/739 PASSING (was 736 + 3 failing + crash)
tsc --noEmit	0 errors
next build	Succeeds
Bugs Fixed by Auditor	BUG-002, BUG-008, BUG-010 + 3 correctness fixes
Bugs Still Open	1 (BUG-009, demo data only)
Remaining Issues	3 (H1: as any, H2: admin tests, Phase 4: DB migration)

1. Executive Summary

The auditor (commit 8d61e2f) made significant fixes across 8 files: correctness fixes (balance-as-of timezone, period-lock date formatting), dead code cleanup (BUG-002 parallel aggregates, BUG-010 removed dead discountAmount input), test suite repair (BUG-008 csv-export crash), and a forward-looking branded Paise type that enables type-safe paise migration. The test suite is now fully green at 739/739 (was 736 passing + 3 failing + a Jest worker crash).

This audit verifies the auditor's fixes, scans for new issues, and identifies what remains. The codebase is in its healthiest state ever: zero tsc errors, zero build errors, all tests passing, no error-leaking routes, no SQL injection risks, no unhandled promise rejections, and all tenant isolation verified.

Bottom line: The app is launch-ready from a code quality standpoint. The remaining items (H1: as any cleanup, H2: admin panel tests, Phase 4: DB migration) are improvements, not blockers. The branded Paise type the auditor introduced is the right foundation for a safe Phase 4 — it lets TypeScript catch rupee/paise mixups at compile time once the helper parameters are flipped.

2. Auditor's Fixes — Verified

The auditor's commit (8d61e2f) modified 8 files. Each fix was verified against the codebase and test suite.

Fix	File(s)	Verification
BUG-002: computePartyBalance parallel aggregates	src/lib/party-balance.ts	VERIFIED — 6 aggregates in single Promise.all, dead paymentsAgg removed
BUG-008: csv-export test crash	src/__tests__/lib/csv-export.test.ts	VERIFIED — test passes, no Jest worker crash
BUG-010: item.discountAmount dead input	src/lib/validation.ts	VERIFIED — field removed from transactionItemSchema
Balance-as-of timezone fix	src/app/api/parties/[id]/balance-as-of/route.ts	VERIFIED — uses T23:59:59.999+05:30 (IST end-of-day)
Balance-as-of accuracy caveat	src/app/api/parties/[id]/balance-as-of/route.ts	VERIFIED — accuracyWarning surfaced when invoice edited after as-of date
Balance-as-of roundMoney parity	src/app/api/parties/[id]/balance-as-of/route.ts	VERIFIED — running balance uses roundMoney (was Math.round)
Period-lock IST date formatting	src/lib/period-lock.ts	VERIFIED — PeriodLockedError formats in Asia/Kolkata
Branded Paise type	src/lib/money.ts	VERIFIED — Paise branded type, helpers return Paise, compiles clean
Tenant-isolation test updates	src/__tests__/lib/tenant-isolation.test.ts	VERIFIED — tests now verify M3 fix (enforced fields win)

No regressions found. The auditor's changes are clean — all 739 tests pass, tsc reports 0 errors, and the production build succeeds. The branded Paise type is a particularly thoughtful addition: it widens to number freely (so existing callers compile), but creates a path for type-safe paise migration in Phase 4.

3. Codebase Metrics (Current State)

Metric	V7 (Pre-Auditor)	V18 (Post-Auditor)	Trend
Test Files	30	35	+5
Individual Tests	~573	739	+166
Tests Passing	736/573* (3 failing + crash)	739/739	All green
tsc Errors	0	0	Stable
API Routes	~55	62	+7
Prisma Models	~51	53	+2
Lib Modules	~53	56	+3
TODO/FIXME	2	2	Stable
console.log (prod code)	7	0**	All removed
"as any" files	49	52	+3 (see § 5)
Routes with apiError()	29/55 (53%)	35/62 (56%)	+6

*V7 report counted ~573 tests but 3 were failing and csv-export crashed the worker. **4 remaining console.log references are all in comments/documentation, not actual code.

4. Security Scan

4.1 Error Handling — No Leaks

Scanned all 62 API routes for error details leaking to clients. **Zero routes leak error.message or String(error) to the client response.** 27 routes don't use the `apiError()` helper (which adds an `errorId` for log lookup), but they all return generic error messages. The 35 routes that do use `apiError()` log the full error server-side and return only a generic message + `errorId`.

4.2 SQL Injection — None

Scanned all `$queryRaw` calls for string interpolation of user input. All raw SQL uses Prisma's tagged template literal syntax (`${"${"}{param}`) which parameterizes automatically. No string concatenation of user input into SQL. **Zero SQL injection risks found.**

4.3 Tenant Isolation — Verified

Scanned all `db.*.findMany/findFirst/update/delete` calls for missing `userId` in the `WHERE` clause. All queries include `userId` filtering (via `activeTransactionWhere()` helper or inline). **Zero tenant isolation gaps found.**

4.4 Authentication Coverage

8 API routes have no auth check — all are expected: `auth/*` (5 routes, they ARE the auth endpoints), `announcements` (public), `feature-flags` (public), `warmup` (DB ping, no user data), and the root `/api` route. **No auth gaps on data-bearing routes.**

4.5 Security Headers

Header	Main App	Admin Panel
X-Frame-Options: DENY	Present	Present
X-Content-Type-Options: nosniff	Present	Present
Referrer-Policy	Present	Present
HSTS (preload)	Present	Present
Permissions-Policy	Present (camera=self)	Present (all blocked)
CSP	Enforced (nonce-based, middleware)	Report-only (unsafe-inline, no unsafe-eval)

5. Remaining Issues

5.1 BUG Registry Status

Of the 10 bugs cataloged during the paise migration, 8 are now FIXED (5 by the agent, 3 by the auditor). Only 1 remains open (plus 1 data issue).

ID	Severity	Description	Status
BUG-010	Low	item.discountAmount dead input	FIXED by auditor
BUG-009	Low	GSTR-1 reconciliation demo data mismatch	OPEN (data issue, not code)
BUG-008	Medium	csv-export test crash	FIXED by auditor
BUG-007	Medium	Reconciliation test mock misroutes SQL	FIXED (agent)
BUG-006	High	Orphaned-items check always returns 0	FIXED (agent)
BUG-005	Low	validation.test.ts tsc errors	FIXED (agent)
BUG-004	Medium	openingBalance not rounded on PUT	FIXED (agent)
BUG-003	Low/Medium	COUNT(*) includes income/expense	FIXED (agent)
BUG-002	Low	computePartyBalance sequential batches	FIXED by auditor
BUG-001	—	Reserved placeholder	WONTFIX

5.2 Open Issues (Not Bugs)

H1: as any in 52 files

Type safety debt. 52 files contain at least one as any cast. Top offenders: period-lock.test.ts (17), auth.ts (10), Settings.tsx (6), csv-export.test.ts (6), get-auth.ts (5). The auditor's branded Paise type is the foundation for fixing the money-related casts — once helper parameters require Paise, the compiler will catch rupee/paise mixups. The auth-related casts need NextAuth type declaration file (next-auth.d.ts). Severity: Medium (no known runtime bugs, but type-checker blind spots). Effort: 4-8 hours.

H2: Admin panel has zero test files

The bahikhata-admin repo has no test infrastructure. All admin code (rate limiting, 2FA, SQL runner, CSRF) is untested. Severity: Medium (admin panel has few users but high security sensitivity). Effort: 1-2 days to set up Jest + write tests for auth, rate-limit, and middleware.

Phase 4: DB Float-to-Int migration

The DB columns are still Float (rupees). Phases 1-3 of the paise migration eliminate all practical float-drift risks (SQL uses integer rounding, computation uses paise arithmetic). The auditor's branded Paise type enables a type-safe Phase 4: flip the helper parameters to require Paise, and

the compiler catches every rupee/paise mixup. Severity: Low (no correctness issues today). Effort: 2-3 days when ready. Recommendation: defer until real customer data exists.

Admin CSP: still report-only + unsafe-inline

The admin panel CSP is Content-Security-Policy-Report-Only (not enforced) and still allows unsafe-inline for scripts. Switching to enforced nonce-based CSP requires middleware changes. Severity: Low (admin panel is not public-facing). Effort: 2-4 hours (add nonce middleware).

6. New Bugs Check

Scanned the auditor's 8 modified files for regressions or new issues introduced by the fixes. **No new bugs found.**

6.1 money.ts (branded Paise type)

The branded Paise type (type Paise = number & { readonly __brand: 'paise' }) widens to number freely, so every existing caller compiles. The paise-producing helpers (toPaise, addPaise, multiplyPaise, calculateGstPaise, splitGstPaise) now return Paise. The 0 as Paise cast in toPaise (line 293) is the only hand-cast — acceptable for the zero-value fallback. **Clean.**

6.2 party-balance.ts (BUG-002 fix)

The 6 aggregates now run in a single Promise.all. The dead paymentsAgg (total-of-both-types) was removed — verified that paymentsReceived and paymentsPaid now come from receivedAgg and paidAgg respectively (which were already being fetched). No logic change, just fewer round-trips. **Clean.**

6.3 balance-as-of route (timezone + accuracy caveat)

The IST end-of-day fix (T23:59:59.999+05:30) is correct — a transaction at 2 AM IST on July 9 is no longer counted in "as of July 8". The roundMoney usage for running balance is correct (parity with headline). The accuracyWarning detection (invoice edited after as-of date) is a thoughtful user-facing honesty feature. **Clean.**

6.4 period-lock.ts (IST date formatting)

The PeriodLockedError message now formats dates in Asia/Kolkata timezone. Verified: uses toLocaleDateString with timeZone: 'Asia/Kolkata'. **Clean.**

6.5 validation.ts (BUG-010 fix)

The per-item discountAmount field was removed from transactionItemSchema. The order-level discountAmount (on createTransactionSchema and updateTransactionSchema) is unchanged — correct, since that's the one actually used by computeLineItems. **Clean.**

6.6 Test files (csv-export, period-lock, tenant-isolation)

csv-export.test.ts: the await fix and real jsdom anchor resolve the worker crash.
tenant-isolation.test.ts: the two IDOR-asserting tests now verify the M3 fix (enforced fields win).
period-lock.test.ts: updated for the IST date format. All 739 tests pass. **Clean.**

7. Verification Results

7.1 Test Suite — Fully Green

739 tests, 35 test files, 0 failures, 0 crashes. The test suite runs in ~3 seconds. This is the healthiest the test suite has ever been. The auditor's csv-export fix resolved the Jest worker crash that was masking 3 failing tests.

7.2 TypeScript — Clean

`npx tsc --noEmit` reports 0 errors. The branded Paise type compiles cleanly — it widens to number so no caller needed updating.

7.3 Production Build — Succeeds

`npx next build` succeeds. All 62 API routes compile. All pages prerender or are correctly marked as dynamic.

7.4 ESLint — Clean

`npx eslint` on all modified files reports 0 errors.

8. Recommendation

The codebase is in launch-ready condition. The auditor's fixes are clean, the test suite is fully green, and no new bugs were introduced. The remaining items are improvements, not blockers.

8.1 Launch Readiness

Dimension	Score	Notes
Correctness	9.5/10	All money paths use roundMoney or paise arithmetic. No float-drift bugs.
Security	9/10	All headers present, no error leaks, tenant isolation verified. Admin CSP still report-only.
Test Coverage	9.5/10	739 tests, all green. Admin panel has zero tests (the only gap).
Type Safety	8/10	0 tsc errors, but 52 files have `as any`. Branded Paise type is foundation for improvement.
Build/Deploy	10/10	Build succeeds, 0 tsc errors, all tests pass.
Overall	9.2/10	Launch-ready. Remaining items are improvements, not blockers.

8.2 Recommended Next Steps (Priority Order)

- **Launch the app.** The code is ready. Get real users and real data. The remaining items can be addressed iteratively post-launch.
- **Fix BUG-009 (GSTR-1 demo data).** Run `/api/admin/repair-headers?fix=true` to repair the demo data, or re-seed fresh demo data. This is a data issue, not a code bug.
- **H1: Reduce `as any` in auth.ts and get-auth.ts.** Create a next-auth.d.ts declaration file to properly extend NextAuth types. This removes 15 of the 52 `as any` casts from the most security-critical files. Effort: 1-2 hours.
- **H2: Add admin panel test infrastructure.** Set up Jest in bahikhata-admin, write tests for admin-auth.ts, admin-rate-limit.ts, and middleware.ts. Effort: 1-2 days.
- **Phase 4: DB Float-to-Int migration.** The auditor's branded Paise type makes this safer. Flip helper parameters to require Paise, then migrate columns. Defer until real customer data exists and there's a dedicated migration window. Effort: 2-3 days.
- **Admin CSP: switch to enforced nonce-based.** Add nonce middleware to admin panel, switch from Report-Only to Enforced. Effort: 2-4 hours.

Report generated: 2026-07-12

Repository: github.com/rahulkothari677/bahikhata-pro

Auditor commit: 8d61e2f (V18)

Test suite: 739/739 passing

tsc: 0 errors

Build: succeeds